

NAMED PRINCIPAL

No agent without a named principal

Twelve controls for governing AI agents

Mapped to IMDA, MAS, NIST, ISO/IEC 42001 and the EU AI Act

Edition 1.0 · July 2026

Aseem Mohan

Contents

Contents	2
How to use this report.....	3
The control gap.....	4
What each regime expects	4
Why the gap persists	4
The twelve controls	5
Discovery & inventory	5
Identity & attribution.....	7
Entitlement & least privilege	9
Credential handling	11
Audit & containment	13
Lifecycle & recertification	15
Sequencing by readiness tier.....	17
Tier 0 — Unmapped (0–9)	17
Tier 1 — Documented (10–18)	17
Tier 2 — Controlled (19–27)	17
Tier 3 — Attested (28–36)	17
Sources and further reading.....	18
About	18

How to use this report

This document sets out twelve controls for governing AI agents, each mapped to the provisions that regulators and auditors in five frameworks will look for. It is written for the person who has to implement them, not for the person who has to describe them.

Each control follows the same structure:

Section	What it gives you
Control statement	One sentence you can lift directly into a control library.
Why it matters	The failure mode, so you can justify the work to someone who controls budget.
What good looks like	Four markers that distinguish a real control from a documented intention.
Evidence expected	What an auditor will ask for. Prepare these and the audit is short.
Framework mapping	Where the control lands across IMDA, MAS, NIST, ISO 42001 and the EU AI Act.

Start with your two lowest-scoring controls, not with the whole list. Twelve simultaneous workstreams is how AI governance programmes stall.

A note on the mappings. Framework provisions are cited to help you locate the relevant obligation and assemble evidence once rather than five times. They are indicative and reflect the position as at July 2026. They are not a compliance determination and not legal advice. Where a mapping matters commercially, confirm it against the current text of the instrument and take advice appropriate to your jurisdiction and sector.

The control gap

Five frameworks written by five different bodies, for five different purposes, have converged on the same requirement. Each expects that an autonomous system acting inside an organisation can be identified, that its authority can be traced to a person, and that its actions leave a record. None of them is primarily an identity framework. All of them arrive at identity.

What each regime expects

Framework	Status as at July 2026	The agent expectation
IMDA Model AI Governance Framework for Agentic AI (Singapore)	Published January 2026, updated May 2026. Voluntary.	Unique agent identities tied to a supervising agent or user; threat modelling for memory poisoning, tool misuse and privilege compromise; access limited to minimum necessary tools and data.
MAS Guidelines on AI Risk Management (Singapore, financial sector)	Consulted November 2025 to January 2026; transition period proposed. Supervisory.	Identification and inventory of AI usage; oversight proportionate to materiality; lifecycle management extending to generative AI and AI agents.
NIST AI RMF and companion work (United States)	RMF 1.0 (2023); Generative AI Profile (2024); Cyber AI Profile (December 2025); COSAIS control overlays and CAISI agent standards work in development.	Governance, mapping and management functions; agent-specific SP 800-53 overlays are in development, with NCCoE material noting agents are commonly run as generic service accounts.
ISO/IEC 42001 (international)	Published 2023; ISO/IEC 42005 and 42006 published 2025; accredited certification available from 2026.	A management system: policy, risk assessment, lifecycle control, monitoring and improvement. Certifiable, which makes it the assurance vehicle rather than the technical standard.
EU AI Act	In force. GPAI obligations since August 2025. Most Article 50 transparency duties from August 2026. Stand-alone high-risk obligations deferred to December 2027 by the 2026 Digital Omnibus.	Human oversight including the ability to interrupt; record-keeping; deployer obligations; accuracy, robustness and cybersecurity.

Why the gap persists

Agent identity falls between three functions and is owned by none of them. Identity and access management thinks in humans and service accounts. AI governance thinks in models, datasets and outputs. Security architecture thinks in networks and workloads. An autonomous system that holds credentials, calls tools and takes irreversible actions is none of those things, and so appears on nobody's control matrix.

The second reason is timing. Enterprise agent deployment is accelerating sharply through 2026, while the most concrete technical guidance — agent-specific control overlays and interoperability profiles — is still in development. Organisations are deploying now and will retrofit controls later. That sequence is what created the privileged access management industry twenty years ago, and it is repeating.

The practical consequence: an organisation can satisfy every documentary requirement of an AI governance framework and still be unable to answer the question an incident will actually pose — which agent did this, and who authorised it?

The twelve controls

Grouped into six domains, two controls each. The order is deliberate: discovery precedes identity, identity precedes entitlement, and lifecycle sits last because it is only meaningful once the first four domains hold.

Discovery & inventory

INV-01 — Agent inventory

Maintain a current register of every AI agent operating in the environment, each with a named accountable owner.

This is the dependency for everything else in this document. An entitlement cannot be scoped, a credential cannot be rotated and an attestation cannot be run against an agent nobody has recorded. Industry survey data through 2026 consistently shows the gap between policy and inventory as the single widest in AI governance: most organisations have written a policy, a minority can produce a list.

WHAT GOOD LOOKS LIKE

- A single register, not a spreadsheet per department.
- Each entry carries: owner, business purpose, autonomy tier, systems and data touched, date of last review.
- Reconciled on a defined cycle against the identity provider, cloud audit logs and SaaS admin consoles.
- Vendor-embedded agents and copilots with tool access are in scope, not only agents built in-house.

EVIDENCE AN AUDITOR WILL ASK FOR

- Register export with record-level timestamps.
- Reconciliation working papers showing sources compared and discrepancies resolved.
- Exception log for agents knowingly operating outside the register, with expiry dates.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 1 — Assess and bound the risks upfront
MAS AI Risk Management	AI identification and inventory
NIST AI RMF	MAP 1, MAP 3
ISO/IEC 42001	Clause 6.1; Annex A.4 (resources for AI systems)
EU AI Act	Article 26 — Deployer obligations

INV-02 — Shadow agent detection

Operate an active capability to detect AI agents and tools deployed without security review, with a defined path to bring them into governance.

Agent deployment is cheap, fast and frequently invisible to central IT. A department connecting a scheduling assistant to a shared mailbox, or an engineer wiring an unreviewed integration into a production data store, creates privileged non-human access with no ticket behind it. Detection matters more here than prevention, because prohibition simply moves the activity somewhere you cannot see it.

WHAT GOOD LOOKS LIKE

- Discovery draws on more than one signal: OAuth grant review, SaaS admin consoles, egress patterns, expense data for AI subscriptions.
- Findings route to a named triage owner within a defined service level.
- The triage outcome is onboarding to the register or decommissioning — never silence.
- Detection is periodic and scheduled, not incident-driven.

EVIDENCE AN AUDITOR WILL ASK FOR

- Discovery run records with dates and coverage scope.
- Triage queue showing items detected, decision taken and time to resolution.
- Trend data on detections over time, which is what demonstrates the capability is real.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 1 — Assess and bound the risks upfront
MAS AI Risk Management	AI identification and inventory; oversight of AI usage
NIST AI RMF	MAP 4; GOVERN 1
ISO/IEC 42001	Clause 8.1; Annex A.4
EU AI Act	Article 26 — Deployer obligations

Identity & attribution

IDN-01 — Unique agent identity

Every agent holds a unique identity that is not shared with any other agent, process or human.

Shared identity destroys attribution at the root. If three agents authenticate as the same service account, no log can tell you which one acted, no entitlement can be scoped to one of them, and revoking access for one is an outage for all three. This is the control that makes the remaining eleven auditable, and it is the one most commonly failed — agents are routinely provisioned as generic service accounts, a pattern flagged directly in NIST NCCoE material on agent identity.

WHAT GOOD LOOKS LIKE

- Unique identity is enforced at provisioning, not corrected afterwards.
- Identity is issued through the same authority as other non-human identities, not created ad hoc by the building team.
- Naming convention allows an auditor to distinguish an agent from a service account or an application identity on sight.
- No shared credentials between agents, including in development and test environments.

EVIDENCE AN AUDITOR WILL ASK FOR

- Identity provider export filtered to agent identities, with creation dates and issuing authority.
- Provisioning procedure showing uniqueness enforced as a gate.
- Sample walkthrough: pick three agents from the register and trace each to a distinct identity.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 2 — Meaningful human accountability; Dimension 3 — Technical controls
MAS AI Risk Management	Scope and AI oversight; AI lifecycle management
NIST AI RMF	GOVERN 1; MANAGE 1
ISO/IEC 42001	Annex A.6 (AI system lifecycle); Annex A.9 (responsible use)
EU AI Act	Article 14 — Human oversight; Article 12 — Record-keeping

IDN-02 — Human principal attribution

For any agent action, the organisation can name the human who authorised it, including where the action occurred inside an agent-to-agent delegation chain.

Every framework surveyed in this document converges on this expectation, and no common production stack delivers it. Singapore's agentic AI framework asks for agent identities tied to supervising agents or users. The EU AI Act's human oversight provisions assume a person is in the loop. Multi-agent architectures break the chain precisely where accountability matters most: agent A invokes agent B, and the audit record shows only agent B.

WHAT GOOD LOOKS LIKE

- The register records a named human principal for every agent, and the field is mandatory.
- Delegation across agents preserves the originating principal in the audit record rather than substituting the calling agent.
- Principal is re-confirmed when the named individual changes role or leaves.
- The organisation has tested attribution end to end, not assumed it.

EVIDENCE AN AUDITOR WILL ASK FOR

- A worked traceability example for a multi-agent flow, from action back to authorising human.
- Register field completeness report for the human principal attribute.
- Joiner-mover-leaver linkage showing principal reassignment on departure.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 2 — Meaningful human accountability
MAS AI Risk Management	Scope and AI oversight
NIST AI RMF	GOVERN 2; MEASURE 2
ISO/IEC 42001	Annex A.9; Clause 5.3 (roles and responsibilities)
EU AI Act	Article 14 — Human oversight

Entitlement & least privilege

ENT-01 — Least privilege scoping

Agent entitlements are scoped to the minimum required by the task, and the scoping is verified rather than asserted.

An agent's blast radius is its entitlement set. This is what converts a prompt injection from an annoyance into an incident: an overprivileged agent turns a single manipulated instruction into broad unauthorised access. Over-permissioned non-human access is consistently reported as a leading pain point in non-human identity surveys, and agents inherit the problem in a more dangerous form because they act autonomously.

WHAT GOOD LOOKS LIKE

- Entitlements derive from the documented task, not from a convenient existing role.
- Administrative and broad-scope grants require documented exception approval with an expiry date.
- Scoping is verified against actual usage after deployment, and unused entitlements are removed.
- Write and delete permissions are treated as materially different from read.

EVIDENCE AN AUDITOR WILL ASK FOR

- Entitlement listing per agent, mapped to stated task.
- Exception register with approvers and expiry dates.
- Post-deployment usage analysis showing granted-versus-used entitlements.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 3 — Technical controls and processes
MAS AI Risk Management	AI lifecycle management
NIST AI RMF	MANAGE 1; MANAGE 2
ISO/IEC 42001	Annex A.6; Clause 8.1
EU AI Act	Article 15 — Accuracy, robustness and cybersecurity

ENT-02 — Pre-deployment assessment

Before an agent goes live, its tool bindings, data classifications, reversibility and blast radius are assessed and recorded.

Risk in agentic systems sits in what the agent does, not what it produces. A model evaluation tells you about output quality; it tells you nothing about the fact that the agent can write to a vendor master file. Assessing tool bindings before deployment is the point at which an organisation can still say no cheaply.

WHAT GOOD LOOKS LIKE

- Assessment covers: tools callable, systems writable, data classes touched, reversibility of actions, and worst-case blast radius.
- Irreversible actions — payments, deletions, external communications, record changes — are identified explicitly and treated as a higher tier.
- Assessment is proportionate but universal: every agent gets one, high-risk agents get a deeper one.
- The output is recorded against the register entry, not filed separately.

EVIDENCE AN AUDITOR WILL ASK FOR

- Completed assessments for a sample of agents across risk tiers.
- Evidence that assessment is a deployment gate, such as a pipeline check or change-approval linkage.
- Register showing reversibility and blast radius populated.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 1 — Assess and bound the risks upfront
MAS AI Risk Management	AI lifecycle management; materiality assessment
NIST AI RMF	MAP 2; MAP 5; MEASURE 1
ISO/IEC 42001	Clause 6.1; Annex A.5 (impact assessment); ISO/IEC 42005
EU AI Act	Article 9 — Risk management; Article 15

Credential handling

CRD-01 — Credential issuance and storage

Agent credentials are vaulted, short-lived and issued per task, with no standing long-lived secrets.

Hardcoded keys in configuration files and environment variables remain the most common finding in agent deployments. The failure mode is well documented in the wider non-human identity space: a forgotten identity with elevated rights and no expiry becomes an unmonitored path into production. Agents multiply the number of such identities faster than any previous class of software.

WHAT GOOD LOOKS LIKE

- Secrets held in a managed vault; the agent receives a reference, never an embedded secret.
- Credentials are short-lived and scoped to the specific task and target rather than to a broad role.
- No credential material in source control, configuration files, container images or logs.
- Rotation is automated and does not require a change window.

EVIDENCE AN AUDITOR WILL ASK FOR

- Vault inventory reconciled against the agent register.
- Secret-scanning results across repositories and images.
- Rotation logs demonstrating actual rotation, not policy stating it.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 3 — Technical controls and processes
MAS AI Risk Management	AI lifecycle management
NIST AI RMF	MANAGE 1; SP 800-53 overlays (COSAIIS, in development)
ISO/IEC 42001	Annex A.6; Clause 8.1
EU AI Act	Article 15 — Cybersecurity

CRD-02 — Independent revocation

Any single agent's access can be revoked immediately and independently, without disrupting other agents or services.

Revocation capability is the practical test of whether unique identity was really implemented. Where agents share credentials, revocation becomes an availability decision rather than a security one — and in practice that means it does not happen. The question to ask internally is not whether you could revoke, but whether anyone would authorise it at two in the morning.

WHAT GOOD LOOKS LIKE

- Revocation is a defined runbook with a named owner and a target response time.
- Revoking one agent has no side effects on others, and this has been tested rather than assumed.
- Revocation is available out of hours and does not depend on a single individual.
- Post-revocation verification confirms access is actually gone.

EVIDENCE AN AUDITOR WILL ASK FOR

- Revocation runbook with owner and service level.
- Test records from a live revocation exercise, including verification step.
- Dependency analysis showing no shared credential coupling between agents.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 3 — Technical controls and processes
MAS AI Risk Management	AI lifecycle management; incident management
NIST AI RMF	MANAGE 2; MANAGE 4
ISO/IEC 42001	Annex A.6; Clause 8.1
EU AI Act	Article 14 — Human oversight (stop function); Article 15

Audit & containment

AUD-01 — Action-level audit record

Agent actions are written to a tamper-evident record that is reviewed on a schedule, covering actions taken and not only prompts and outputs.

Most AI logging captures the conversation and misses the consequence. For an agent, the material events are the tool calls, the writes, the escalations and the external communications. A record of what the agent said is not a record of what the agent did, and only the second is auditable.

WHAT GOOD LOOKS LIKE

- The record captures: agent identity, human principal, tool invoked, target system, parameters, outcome and timestamp.
- Logs are centralised and tamper-evident, with retention aligned to the relevant regulatory expectation.
- Review is scheduled and evidenced, not purely reactive to incidents.
- Alerting exists for defined high-risk action patterns.

EVIDENCE AN AUDITOR WILL ASK FOR

- Sample log extract demonstrating the required fields are present.
- Retention configuration and tamper-evidence mechanism documentation.
- Review records showing who reviewed what, when, and what was escalated.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 3 — Technical controls and processes
MAS AI Risk Management	AI lifecycle management; monitoring
NIST AI RMF	MEASURE 2; MEASURE 3; MANAGE 4
ISO/IEC 42001	Clause 9.1 (monitoring and measurement); Annex A.6
EU AI Act	Article 12 — Record-keeping; Article 26(6)

AUD-02 — Containment and stop control

A tested mechanism exists to halt a misbehaving agent mid-task, with defined ownership and response time.

Detection without a stop control is observation, not governance. This is also the control most often documented and least often tested — an untested kill switch is a statement of intent. The relevant question in an audit is not whether the capability exists but when it was last exercised.

WHAT GOOD LOOKS LIKE

- Stop control operates at the agent level, not only by disabling the underlying host or platform.
- Ownership is named and cover extends outside business hours.
- The mechanism is tested on a defined cycle and the test is evidenced.
- Partial containment options exist — suspend, restrict to read-only, revoke specific tools — not only full shutdown.

EVIDENCE AN AUDITOR WILL ASK FOR

- Stop-control procedure with named owner and response time commitment.
- Most recent test record, including time taken and any issues found.
- Integration with incident response, showing the trigger criteria.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 2 — Human accountability; Dimension 3 — Technical controls
MAS AI Risk Management	AI lifecycle management; incident management
NIST AI RMF	MANAGE 2; MANAGE 4
ISO/IEC 42001	Clause 8.1; Annex A.6; Clause 10 (nonconformity)
EU AI Act	Article 14(4) — Ability to intervene or interrupt

Lifecycle & recertification

LFC-01 — Entitlement recertification

Agent entitlements are recertified on a defined cycle through owner attestation, with evidence retained.

Entitlements granted once and never reviewed become standing privilege. This is the oldest lesson in access management and it is being relearned from scratch for non-human identities. The discipline already exists in most regulated organisations in the form of user access review; the gap is that agents are almost never in scope of it. Extending an existing attestation cycle to cover agents is usually faster than building anything new.

WHAT GOOD LOOKS LIKE

- Recertification runs on a schedule, with a defined population and completeness tracking.
- The attester is the accountable owner, not the team that built the agent.
- Revocation decisions are actioned and verified, and the loop is closed.
- Non-response has a defined consequence, typically automatic revocation.

EVIDENCE AN AUDITOR WILL ASK FOR

- Campaign records: population, completion rate, decisions taken.
- Evidence that revocations were executed and verified, not merely recorded.
- Exception handling for agents that could not be certified in cycle.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 2 — Meaningful human accountability
MAS AI Risk Management	Scope and AI oversight; periodic review
NIST AI RMF	GOVERN 1; MANAGE 4
ISO/IEC 42001	Clause 9.2 (internal audit); Clause 10 (improvement)
EU AI Act	Article 26 — Deployer obligations; Article 17 (quality management, providers)

LFC-02 — Decommissioning

Agents are decommissioned when their owner departs or their business purpose ends, and the removal is verified.

An orphaned agent with standing entitlements is the non-human equivalent of a dormant administrator account, with the added property that it may still be executing on a schedule. Owner departure is the trigger most organisations eventually build; purpose change is the trigger almost nobody builds, and it is the more common cause.

WHAT GOOD LOOKS LIKE

- Both triggers are covered: owner departure and purpose termination.
- Departure triggers integrate with the existing leaver process rather than sitting separately.
- Decommissioning removes identity, entitlements and credentials, and confirms the agent has stopped executing.
- Verification is a distinct step with its own record.

EVIDENCE AN AUDITOR WILL ASK FOR

- Decommissioning records for a sample period, including verification.
- Leaver-process documentation showing the agent-ownership check.
- Reconciliation demonstrating no active identities remain for decommissioned agents.

FRAMEWORK MAPPING

Framework	Provision
IMDA Agentic MGF	Dimension 2 — Meaningful human accountability
MAS AI Risk Management	AI lifecycle management
NIST AI RMF	MANAGE 4; GOVERN 1
ISO/IEC 42001	Annex A.6; Clause 8.1
EU AI Act	Article 26 — Deployer obligations

Sequencing by readiness tier

The assessment places an organisation in one of four tiers. The work below is ordered so that each stage makes the next one cheaper.

Tier 0 — Unmapped (0–9)

Agents are running without an identity model. Do not start with controls; start with the register.

- Stand up the agent register. Manual entry is acceptable. Completeness matters more than tooling.
- Assign a named accountable owner to every entry. An entry without an owner is not a register entry.
- Run one discovery pass across OAuth grants and SaaS admin consoles to find what you did not know about.
- Do not attempt recertification, kill switches or attestation yet. They have nothing to operate on.

Tier 1 — Documented (10–18)

Some agents are known and some controls exist, but attribution breaks under scrutiny. Close the identity gap.

- Eliminate shared identities. This is the control that makes everything downstream auditable.
- Make the human principal a mandatory field and backfill it.
- Get credentials out of configuration files and into a vault.
- Test revocation on one agent, end to end, and record what breaks.

Tier 2 — Controlled (19–27)

Controls are in place across most domains. The usual weaknesses are recertification and multi-agent traceability.

- Extend the existing user access review cycle to cover agents. Reuse the machinery you already have rather than building a parallel process.
- Test attribution across an agent-to-agent chain and fix what the test reveals.
- Exercise the stop control and record the time taken.
- Add purpose-change as a decommissioning trigger, not only owner departure.

Tier 3 — Attested (28–36)

Agent identity is governed as a first-class control domain. The remaining work is coverage and proof.

- Extend scope to third-party and vendor-embedded agents, which are usually outside the register.
- Assemble the evidence pack for each control and rehearse it against a mock audit.
- Move from periodic attestation toward continuous entitlement analysis where the estate justifies it.
- Contribute the operating model back to your sector. At this maturity you are ahead of the guidance.

Sources and further reading

Primary instruments and guidance referenced in this document. Positions are as at July 2026 and this area moves quickly; verify against the current text before relying on any mapping.

- IMDA and AI Verify Foundation — Model AI Governance Framework for Agentic AI (Singapore), published January 2026, updated May 2026.
- Monetary Authority of Singapore — Consultation Paper on Guidelines on Artificial Intelligence Risk Management; MAS AI Risk Management Toolkit (March 2026).
- Association of Banks in Singapore — Handbook on Generative AI Guardrails in Banking (March 2026).
- NIST — AI Risk Management Framework 1.0; Generative AI Profile (NIST AI 600-1); Cyber AI Profile; COSAIS control overlays for securing AI systems (in development); CAISI AI Agent Standards Initiative.
- NIST NCCoE — concept paper on AI agent identity and authorization.
- ISO/IEC 42001 (AI management systems); ISO/IEC 42005 (AI system impact assessment); ISO/IEC 42006 (requirements for bodies providing audit and certification).
- Regulation (EU) 2024/1689 (AI Act), as amended by the 2026 Digital Omnibus on AI.
- Cloud Security Alliance and Oasis Security — State of Non-Human Identity and AI Security, 2026.

About

Aseem Mohan leads global identity and access management operations across North America, Canada, Europe and Asia Pacific, covering approximately 45,000 identities in 52 countries. Twenty-two years in cybersecurity across banking, consulting and enterprise, with CISSP, CISM and CISA. Based in Singapore.

This report accompanies the Named Principal readiness assessment. If your organisation is working through any of these twelve controls, I am interested in comparing notes.

© 2026 Aseem Mohan. All rights reserved.

This document is provided for readiness planning. It is not a compliance determination, a certification, or legal advice.